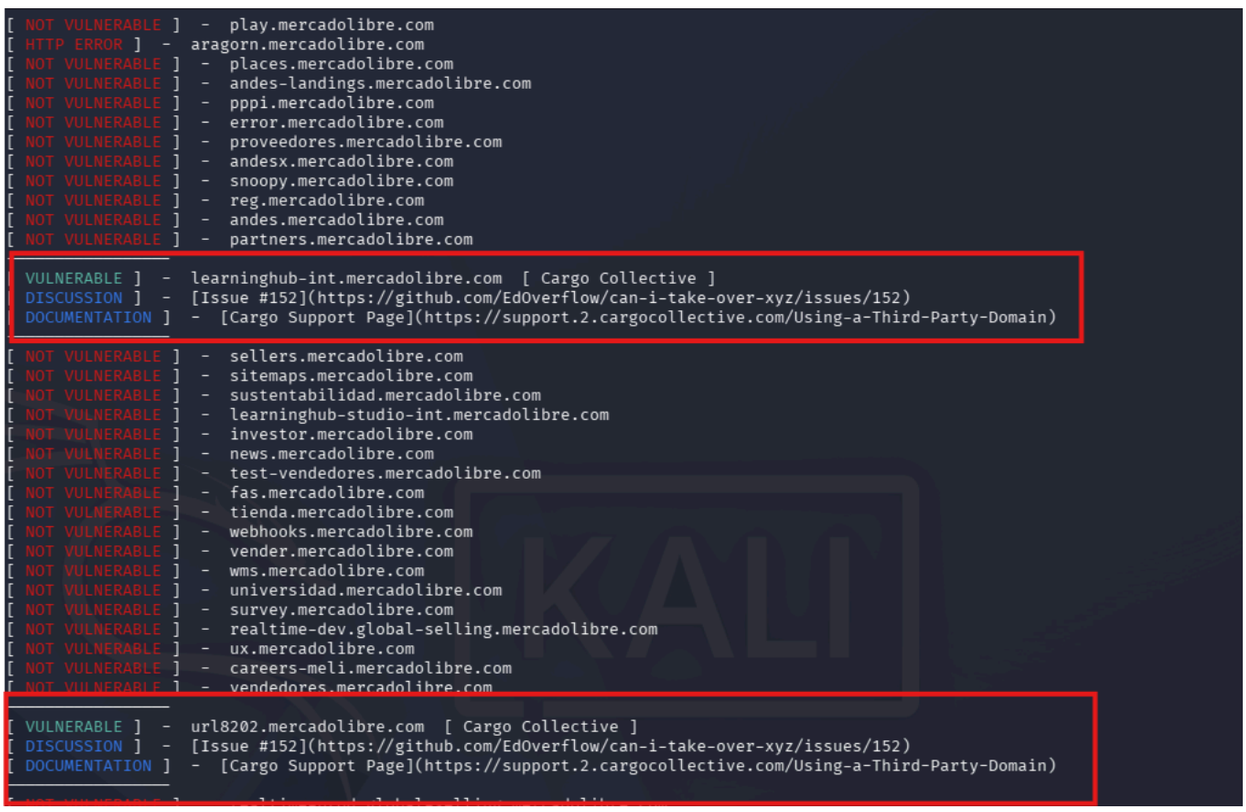
💣 Fase 3: Analisis de Vulnerabilidades: S.Take Over

🔍 Análisis de Subdomain Takeover y Configuraciones DNS

Durante la fase de **análisis de vulnerabilidades** se evaluó la posibilidad de **subdomain takeover** utilizando la herramienta **Subzy**, la cual permite detectar subdominios que podrían estar apuntando a servicios externos susceptibles de ser reclamados por terceros.

Para realizar el escaneo se utilizó la lista de subdominios activos obtenidos en las fases anteriores:




```
subzy run --targets subdominios_vivos_ok.txt
```

El escaneo analizó todos los subdominios vivos identificados previamente y detectó dos casos que inicialmente parecían vulnerables:

```
learninghub-int.mercadolibre.com
url8202.mercadolibre.com
```

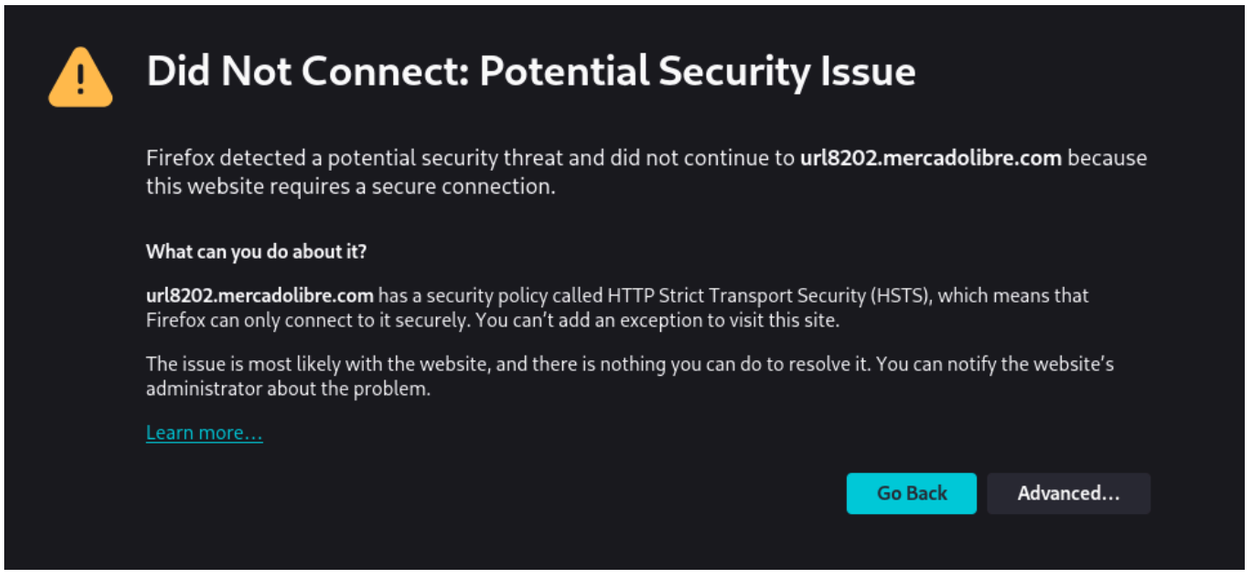
A partir de estos resultados se realizó un **análisis manual** para validar si los hallazgos correspondían a vulnerabilidades reales o a falsos positivos.

🔎 Posible Dangling DNS hacia servicio externo (SendGrid)

El subdominio:

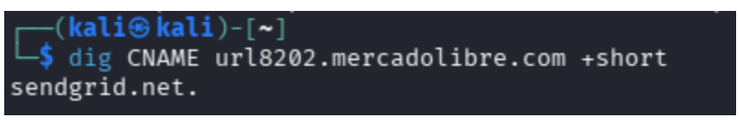
```
url8202.mercadolibre.com
```

presenta un registro DNS que apunta a infraestructura del proveedor externo **SendGrid**, lo que sugiere la presencia de un **Dangling DNS** (registro DNS huérfano).



La verificación del registro CNAME arrojó el siguiente resultado:

```
dig CNAME url8202.mercadolibre.com +short
```




```
sendgrid.net
```

Además, al inspeccionar la respuesta HTTP se observó que el servidor que responde pertenece directamente al proveedor externo:

```
curl -Is http://url8202.mercadolibre.com | grep -E "Server|Via"
```

```
Server: sendgrid
```

La inspección del certificado SSL confirmó que el tráfico llega directamente a la infraestructura del servicio externo. Este comportamiento sugiere que el subdominio **podría ser vulnerable a un caso de Dangling DNS**, donde un tercero podría potencialmente reclamar el recurso en el proveedor externo si el servicio ya no está asociado activamente con la organización.

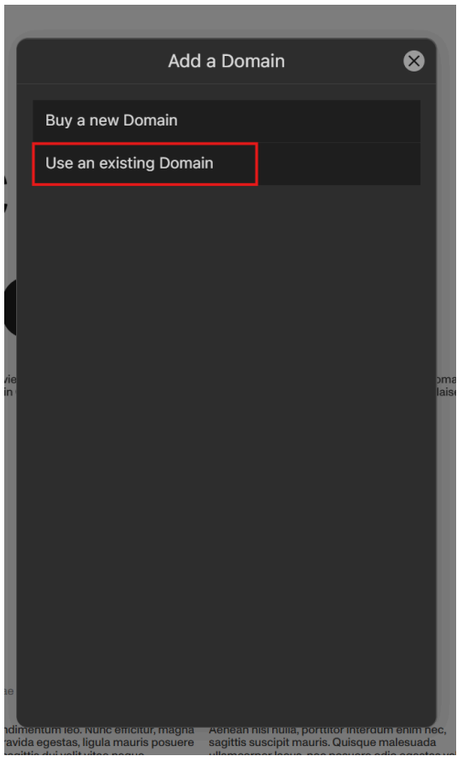
Este tipo de configuración podría permitir ataques como **phishing, distribución de contenido malicioso o suplantación de identidad** utilizando el subdominio legítimo.

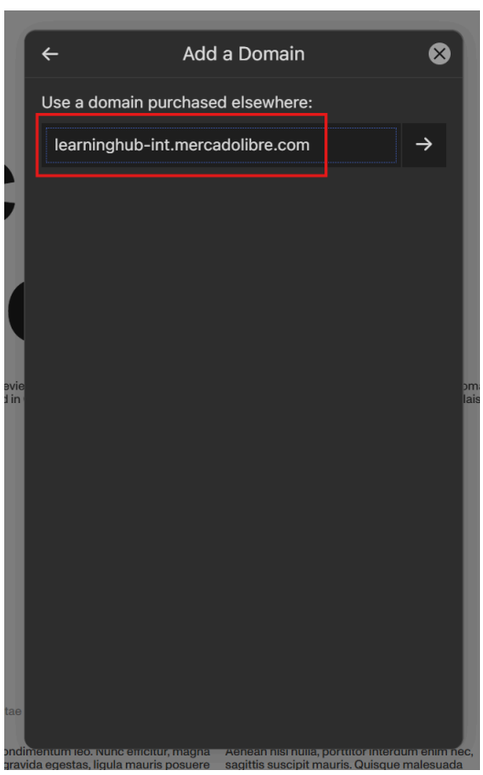
🔎 Análisis de posible Subdomain Takeover (Cargo Collective)

El segundo subdominio identificado fue:

```
learninghub-int.mercadolibre.com
```

Inicialmente parecía susceptible a un posible **subdomain takeover** mediante la plataforma **Cargo Collective**, ya que el servicio permitía iniciar el proceso de asociación del dominio.

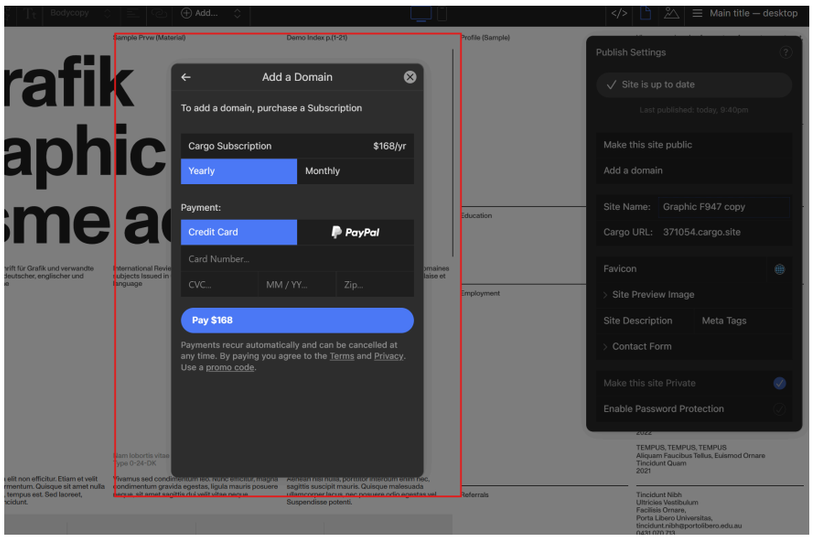




Sin embargo, al analizar el registro DNS se observó que el subdominio apunta a infraestructura interna de la organización a través de un **AWS Application Load Balancer**:

```
dig CNAME learninghub-int.mercadolibre.com +short
```

```
slave-2-orion-alb-1721994217.us-east-1.elb.amazonaws.com
```



Esto indica que el tráfico está gestionado por un **proxy inverso dentro de AWS**, lo que actúa como una capa de protección que impide que el takeover pueda materializarse.

📄 Conclusión

El análisis permitió identificar un caso que **podría representar un Dangling DNS potencialmente vulnerable** (`url8202.mercadolibre.com`) al apuntar a infraestructura externa aparentemente no gestionada activamente. Por otro lado, el segundo subdominio inicialmente marcado como vulnerable resultó estar protegido por la arquitectura de infraestructura implementada, por lo que no se considera explotable.